

Task 15: Vulnerability Assessment & Risk Prioritization

Chapter 1: Scope Definition & Overview of Vulnerability Assessment

1.1 Introduction to Vulnerability Assessment

A **Vulnerability Assessment (VA)** is a systematic process of identifying, analysing, and evaluating security weaknesses in systems, networks, or applications. The goal of a vulnerability assessment is to detect potential security flaws before they can be exploited by attackers.

Unlike penetration testing, which actively exploits vulnerabilities to demonstrate impact, vulnerability assessment focuses on detection, classification, and risk evaluation.

It helps organizations:

- Identify security misconfigurations
- Detect outdated software and exposed services
- Understand risk levels using standardized scoring systems
- Prioritize remediation efforts

In this task, Nessus Essentials was used as the primary vulnerability scanning tool.

1.2 Importance of Defining Scope

Before conducting a vulnerability assessment, it is critical to clearly define the **scope** of the assessment.

Scope definition includes:

- Target systems or IP addresses
- Network boundaries
- Scan type (internal / external)
- Authentication method
- Depth of scanning

Defining scope is important because:

- Prevents unauthorized scanning
- Reduces operational disruption
- Focuses resources on relevant assets
- Ensures compliance with ethical and legal standards

A well-defined scope ensures the assessment is structured, controlled, and effective.

1.3 Scope of this Assessment

For this internship task, the scope of the vulnerability assessment was defined as follows:

- **Target Host:** 127.0.0.1 (Localhost)
- **Environment:** Windows 11 system
- **Tool Used:** Nessus Essentials
- **Scan Type:** Basic Network Scan
- **Scan Mode:** On-demand
- **Authentication:** Non-authenticated scan
- **Objective:** Identify and prioritize vulnerabilities on the local machine

The scan was limited to the local host to ensure safe testing within a controlled environment. No external or third-party systems were scanned.

1.4 Ethical Considerations

The vulnerability assessment was conducted in a controlled lab environment on a self-owned system. No unauthorized systems were targeted. This ensures compliance with ethical cybersecurity practices.

Chapter 2 – Scanner Configuration & Setup

2.1 Overview of Nessus Essentials

Nessus Essentials is a widely used vulnerability assessment tool developed by Tenable. It is designed to detect security weaknesses in operating systems, services, applications, and network configurations.

Nessus works using a large database of vulnerability plugins that:

- Detect misconfigurations
- Identify outdated software
- Map vulnerabilities to CVE entries
- Assign severity ratings using CVSS scoring

In this task, Nessus Essentials was used to perform a non-authenticated vulnerability scan on the local system.

2.2 Installation & Activation

The following steps were performed to configure the scanner:

1. Downloaded Nessus Essentials (Windows 64-bit).
2. Installed the Nessus service locally.
3. Accessed the Nessus web interface at:
4. <https://localhost:8834>
5. Activated the product using an official activation key.
6. Completed plugin initialization and setup.

The scanner was successfully configured and accessible through the local web interface.

2.3 Scan Policy Selection

For this assessment, the **Basic Network Scan** policy was selected.

This policy includes:

- Port scanning

- Service detection
- Vulnerability plugin checks
- CVE mapping
- CVSS scoring

The Basic Network Scan is suitable for:

- General vulnerability identification
- Internal host assessments
- Non-intrusive scanning

2.4 Target Configuration

The defined scan target was:

- **IP Address:** 127.0.0.1
- **Hostname:** Localhost
- **Scan Type:** On-demand
- **Authentication:** Non-authenticated

The scan was limited to the local machine to ensure controlled and ethical testing.

2.5 Authenticated vs Non-Authenticated Scans:

Vulnerability scans can be conducted in two ways:

➤ Non-Authenticated Scan

- Scanner evaluates exposed services externally.
- Does not log into the system.
- Limited visibility.
- Simulates external attacker perspective.

➤ Authenticated Scan

- Uses system credentials.

- Provides deeper system inspection.
- Detects patch levels and internal misconfigurations.

In this task, a non-authenticated scan was performed.

2.6 Scanner Readiness Verification

Before launching the scan, the following were verified:

- Nessus service running
- Plugins updated
- License active
- Target correctly defined
- Scan policy configured

The scanner was successfully prepared for execution.

Chapter 3 – Scan Execution & Monitoring

3.1 Launching the Vulnerability Scan

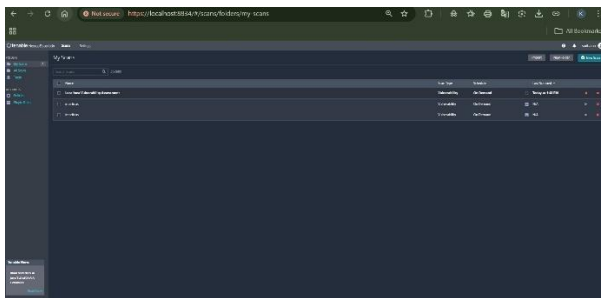
After configuring the scanner and defining the scope, the vulnerability scan was initiated using the **Basic Network Scan** policy.

The scan was launched through the Nessus dashboard under:

My Scans → Localhost Vulnerability Assessment → Launch

The scan targeted:

- IP Address: 127.0.0.1
- Scan Mode: On-demand
- Scan Type: Non-authenticated



3.2 How Nessus Performs Scanning

When a scan is launched, Nessus performs several automated processes:

1. Host Discovery

Determines whether the target host is active.

2. Port Scanning

Identifies open ports (e.g., 445 for SMB, 443 for HTTPS, etc.).

3. Service Detection

Identifies services running on open ports.

4. Plugin Execution

Executes vulnerability plugins to check for:

- Known CVEs
- Misconfigurations
- Weak encryption protocols
- Outdated services

5. Vulnerability Matching

Matches findings against vulnerability databases.

6. CVSS Assignment

Assigns severity scores using CVSS standards.

3.3 Scan Monitoring

During execution, the scan status was monitored through the Nessus interface.

The interface displayed:

- Running status
- Progress indicator
- Last scanned timestamp
- Host scanning details

Monitoring ensures:

- Scan is progressing correctly
- No interruptions occur
- Results are being generated properly

3.4 Scan Completion

Upon completion, the scan status changed to:

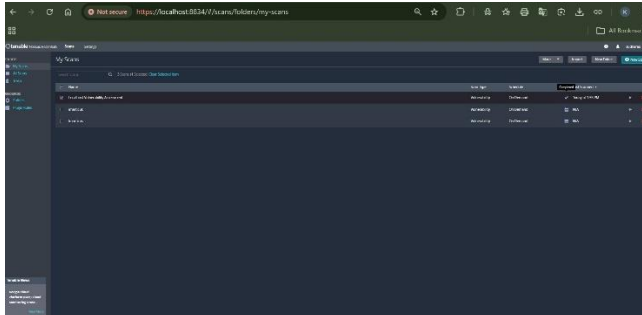
✓ Completed

The results included:

- Total number of vulnerabilities detected

- Severity distribution (Critical, High, Medium, Low, Informational)
- Detailed plugin-based findings

The scan successfully identified multiple medium and informational vulnerabilities.



3.5 Importance of Monitoring During Scans

Monitoring is important because:

- Ensures the scanner is functioning correctly
- Detects performance issues
- Prevents incomplete or interrupted scans
- Validates that the full vulnerability database was applied

Proper monitoring improves accuracy and reliability of results.

Chapter 4 – Severity Analysis & CVSS Scoring

4.1 Understanding Vulnerability Severity Levels

Vulnerability severity levels help determine the risk impact of identified weaknesses. Nessus classifies vulnerabilities into five categories based on the **CVSS (Common Vulnerability Scoring System)** score.

The severity levels are:

Severity Level	CVSS Score Range	Risk Level
Critical	9.0 – 10.0	Severe Risk
High	7.0 – 8.9	Significant Risk
Medium	4.0 – 6.9	Moderate Risk
Low	0.1 – 3.9	Minor Risk
Informational	0.0	No direct risk

These categories help security teams prioritize remediation efforts.

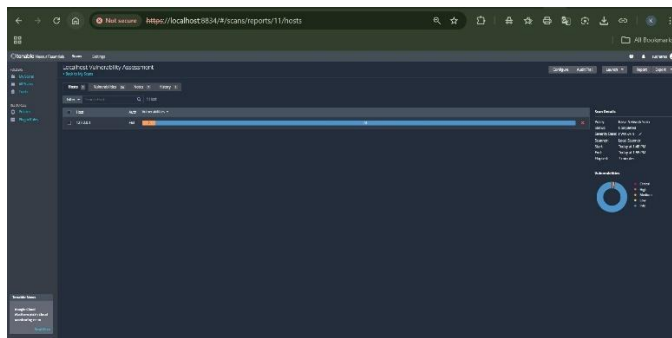
4.2 Overview of CVSS (Common Vulnerability Scoring System)

CVSS is a standardized framework used to evaluate the severity of vulnerabilities. It considers factors such as:

- Exploitability
- Impact on confidentiality
- Impact on integrity
- Impact on availability
- Attack complexity
- Required privileges

The CVSS score ranges from 0 to 10, where higher scores indicate greater risk.

Nessus uses CVSS v3 to assign severity ratings automatically.

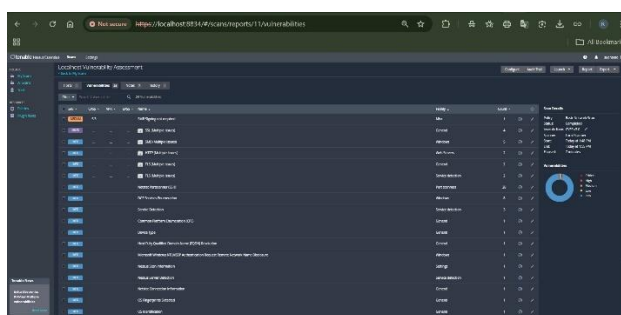


4.3 Severity Distribution from the Assessment

The vulnerability assessment of the localhost system resulted in:

- Critical: 0
- High: 0
- Medium: (Observed in scan results)
- Low: (Observed if any)
- Informational: Multiple findings

The highest severity detected was **Medium**, indicating that no immediate critical threats were present. However, medium-level vulnerabilities still require attention and remediation planning.



4.4 Example Severity Analysis

Vulnerability: SMB Signing Not Required

- Severity: Medium
- CVSS Score: 5.3
- Port: 445/tcp

- Plugin ID: 57608

This vulnerability indicates that SMB communication does not require digital signing. While not immediately exploitable remotely, it increases the risk of man-in-the-middle (MITM) attacks within internal networks.

The CVSS score of 5.3 reflects moderate risk due to:

- Network-based attack vector
- Potential impact on integrity
- Requirement of local network access

4.5 Interpretation of Findings

Although no critical or high vulnerabilities were detected, the presence of medium-level vulnerabilities suggests:

- Configuration weaknesses exist
- Hardening measures can be improved
- Security posture can be strengthened

Informational findings highlight:

- Service detection
- Protocol configurations
- System enumeration data

These may not represent immediate threats but provide valuable system insight.

Chapter 5 – Mapping to CVE & Vulnerability Identification

5.1 Understanding CVE (Common Vulnerabilities and Exposures)

CVE stands for **Common Vulnerabilities and Exposures**. It is a standardized identification system used globally to uniquely identify publicly known security vulnerabilities.

Each CVE entry includes:

- A unique ID (e.g., CVE-2023-XXXX)
- Description of the vulnerability
- References
- Severity metrics
- Affected systems

CVE helps ensure consistency in vulnerability reporting and tracking across tools and organizations.

5.2 How Nessus Maps Vulnerabilities

Nessus uses a large database of vulnerability plugins. Each plugin:

- Detects a specific vulnerability or misconfiguration
- References CVE entries (if applicable)
- Assigns a CVSS score
- Provides remediation guidance
- Includes a Plugin ID for tracking

When Nessus detects a vulnerability:

1. It matches service/version information.
2. It compares against known vulnerability databases.
3. It assigns severity based on CVSS scoring.

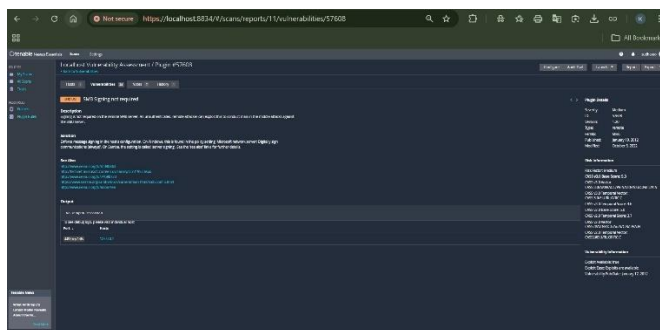
5.3 Example Vulnerability Mapping

Vulnerability Identified:

SMB Signing Not Required

- Plugin ID: 57608
- Port: 445/tcp
- Severity: Medium
- CVSS Score: 5.3

This finding indicates that the SMB service does not require digital signing for communications. While this issue may not directly reference a specific CVE, it represents a security misconfiguration that increases risk exposure.



Some vulnerabilities detected by Nessus may:

- Reference specific CVEs
- Represent best-practice configuration issues
- Identify deprecated protocols (e.g., TLS issues)
- Detect insecure service configurations

5.4 Importance of CVE Mapping

Mapping vulnerabilities to CVE entries is important because it:

- Enables global tracking of known weaknesses
- Assists in patch management
- Supports compliance requirements
- Helps prioritize risk remediation
- Facilitates threat intelligence integration

Organizations use CVE mapping to:

- Align vulnerability management with industry standards
- Monitor exploit trends
- Assess risk exposure against known threats

5.5 Role of Plugin IDs

Each Nessus vulnerability finding includes a Plugin ID. This ID:

- Identifies the detection mechanism used
- Links to detailed vulnerability documentation
- Helps track scanner updates
- Ensures reproducibility of findings

For example:

Plugin ID 57608 corresponds to the SMB Signing Not Required detection module.

Chapter 6 – Risk Classification & Impact Analysis

6.1 Understanding Risk in Vulnerability Assessment

A vulnerability alone does not define risk. Risk is determined by evaluating:

- The likelihood of exploitation
- The potential impact on the system or organization

Risk can be expressed as:

$$\text{Risk} = \text{Likelihood} \times \text{Impact}$$

Even a medium vulnerability can pose high risk depending on environment and exposure.

6.2 Factors Influencing Risk Level

The following factors influence risk classification:

- **Exposure**

Is the vulnerable service publicly accessible?

- **Exploitability**

Is exploit code publicly available?

- **Attack Complexity**

Does exploitation require advanced skills?

- **Required Privileges**

Does the attacker need authentication?

- **Business Criticality**

Is the affected system business-critical?

In this assessment, the target was localhost (127.0.0.1), which limits exposure significantly.

6.3 Risk Classification of Findings

Based on the Nessus scan results:

- No Critical vulnerabilities detected

- No High severity findings
- Medium vulnerabilities present
- Informational findings identified

The highest severity identified was Medium, indicating moderate risk.

Example classification:

SMB Signing Not Required

- Likelihood: Moderate (requires internal network access)
- Impact: Moderate (potential for MITM attacks)
- Risk Level: Medium

6.4 Business Impact Consideration

Although the scan was conducted on a local system, in an enterprise environment such vulnerabilities could lead to:

- Credential interception
- Lateral movement within network
- Data integrity compromise
- Privilege escalation scenarios

Therefore, even medium vulnerabilities should not be ignored.

6.5 Risk Matrix Representation

A simplified risk matrix helps visualize classification:

Impact \ Likelihood	Low Likelihood	Medium Likelihood	High Likelihood
Low Impact	Low Risk	Low Risk	Medium Risk
Medium Impact	Low Risk	Medium Risk	High Risk
High Impact	Medium Risk	High Risk	Critical Risk

The identified vulnerabilities fall under:

Medium Impact + Medium Likelihood → Medium Risk

6.6 Importance of Risk-Based Approach

Modern vulnerability management focuses on risk prioritization rather than fixing all findings blindly.

Risk-based assessment helps:

- Allocate resources efficiently
- Address the most impactful weaknesses first
- Reduce overall attack surface
- Improve security posture strategically

Chapter 7 – Risk Prioritization & Remediation Strategy

7.1 Importance of Risk Prioritization

Not all vulnerabilities can or should be fixed at the same time. Security teams must prioritize findings based on:

- Severity level
- Potential business impact
- Exploitability
- System exposure
- Resource availability

A structured prioritization strategy ensures that the most impactful vulnerabilities are addressed first.

7.2 Risk Priority Classification from Assessment

Based on the Nessus scan results:

- Critical: 0
- High: 0
- Medium: Present
- Low: Minimal
- Informational: Multiple

Since no Critical or High vulnerabilities were identified, Medium-level findings were treated as highest priority.

7.3 Risk Priority List

Priority Level	Vulnerability	Severity	CVSS Score	Recommended Action
1	SMB Signing Not Required	Medium	5.3	Enable SMB signing via Group Policy

Priority Level	Vulnerability	Severity	CVSS Score	Recommended Action
2	SSL / TLS Configuration Issues	Medium	Varies	Disable weak protocols and enforce TLS 1.2+
3	Informational Findings	Info	0	Monitor and review configuration

This prioritization ensures moderate-risk misconfigurations are addressed before minor informational observations.

7.4 Remediation Strategy

1. SMB Signing Not Required

Risk: Possible man-in-the-middle attacks on internal network

Fix: Enable SMB message signing in Windows security policy

2. SSL/TLS Multiple Issues

Risk: Weak encryption protocols may allow downgrade attacks

Fix: Disable outdated protocols (e.g., TLS 1.0 / 1.1) and enforce secure cipher suites

3. Informational Findings

Risk: No immediate threat

Fix: Maintain documentation and monitor changes

7.5 General Hardening Recommendations

In addition to specific fixes, the following best practices are recommended:

- Regular patch management
- Disable unnecessary services
- Enforce secure protocol configurations
- Enable logging and monitoring
- Perform periodic vulnerability scans

7.6 Limitation of the Assessment

This assessment was:

- Non-authenticated
- Limited to localhost
- Conducted in a controlled environment

Therefore, deeper system vulnerabilities may not have been fully evaluated.

Chapter 8 – Conclusion & Outcome

8.1 Summary of the Assessment

This vulnerability assessment was conducted using Nessus Essentials on the localhost system (127.0.0.1). The objective was to identify, analyse, and prioritize security weaknesses within a controlled environment.

The scan successfully:

- Identified open services and configurations
- Detected multiple vulnerabilities
- Classified findings based on severity
- Mapped vulnerabilities using CVSS scoring
- Generated actionable remediation recommendations

A total of 24 findings were identified, with the highest severity categorized as Medium.

8.2 Key Findings

- No Critical vulnerabilities detected
- No High severity vulnerabilities identified
- Presence of Medium severity misconfigurations (e.g., SMB Signing Not Required)
- Multiple Informational findings related to system configuration and service detection

This indicates that while no immediate critical threats were present, certain configuration improvements are recommended to strengthen system security posture.

8.3 Risk Evaluation Outcome

Based on the risk analysis:

- The overall system risk level is considered Moderate.
- The identified vulnerabilities require remediation planning but do not pose immediate catastrophic impact.
- Internal configuration hardening can further improve system resilience.

8.4 Skills Developed Through This Task

This task enhanced the following practical cybersecurity skills:

- Vulnerability scanning using Nessus Essentials
- Understanding CVSS and severity classification
- Mapping vulnerabilities to standardized identifiers
- Risk classification and prioritization
- Writing structured vulnerability assessment reports
- Interpreting security findings in business context

8.5 Final Remarks

Vulnerability assessment is a proactive security measure that helps organizations detect weaknesses before they are exploited. While this assessment was limited to a local environment, the methodology followed reflects real-world vulnerability management practices.

Continuous monitoring, periodic scanning, and proper remediation planning are essential to maintaining a secure IT infrastructure.